(9条消息) Mybatis中防止Sql注入_Daniel的博客-CSDN博客

原创

包子林黄辉冯 2019-05-25 21:33:52 9551 收藏 13

最后发布:2019-05-25 21:33:52首次发布:2019-05-25 21:33:52

版权声明：本文为博主原创文章，遵循 CC 4.0 BY-SA 版权协议，转载请附上原文出处链接和本声明。

一、什么是Sql注入

sql注入是一种代码注入技术，将恶意的sql插入到被执行的字段中，以不正当的手段多数据库信息进行操作。

在jdbc中使用一般使用PreparedStatement就是为了防止sql注入。

```
1. 比如代码 : "select * from user where id =" + id;
2. 正常执行不会出现问题，一旦被sql注入，比如将传入参数id="3 or 1 = 1”，那么sql会变成
3. "select * from user where id = 3 or 1 = 1",这样全部用户信息就一览无遗了。
```

二、MyBatis中防止sql注入

下面是Mybatis的两种sql。

```
1.   <select id="selectByPrimaryKey" resultMap="BaseResultMap"
2.                        parameterType="java.lang.Integer" >
3.
4.     <include refid="Base_Column_List" />
5.
6.     where id = #{id,jdbcType=INTEGER}
7.
```

```
1.   <select id="selectByPrimaryKey" resultMap="BaseResultMap"
2.                         parameterType="java.lang.Integer" >
3.
4.     <include refid="Base_Column_List" />
5.
6. where id = ${id,jdbcType=INTEGER}
7.
```

可以很清楚地看到，主要是#和$的区别。

将sql进行预编译"where id = ?"，然后底层再使用PreparedStatement的set方法进行参数设置。

$ 将传入的数据直接将参数拼接在sql中，比如 “where id = 123”。

因此，#与$相比，#可以很大程度的防止sql注入，因为对sql做了预编译处理，因此在使用中一般使用#{}方式。

三、演示

在项目中配置log4j。方便查看sql日志。

#方式

```
1. 查看日志，sql进行了预编译，使用了占位符，防止了sql注入。
2. [cn.jxust.cms.dao.UserMapper.selectByPrimaryKey] - ==>  Preparing: select id, stuId, username, password, type, info from user where id = ?
3.   [cn.jxust.cms.dao.UserMapper.selectByPrimaryKey] - ==> Parameters: 1(Integer)
4.   [cn.jxust.cms.dao.UserMapper.selectByPrimaryKey] - <==      Total: 1
```

$方式

```
1.
2.  [cn.jxust.cms.dao.UserMapper.selectByPrimaryKey] - ==>  Preparing: select id, stuId, username, password, type, info from user where id = 1
3.   [cn.jxust.cms.dao.UserMapper.selectByPrimaryKey] - ==> Parameters:
4.   [cn.jxust.cms.dao.UserMapper.selectByPrimaryKey] - <==      Total: 1
5.
6.
```

附：使用$方式时，需要在mapper接口中使用@Param注解。否则会报**There is no getter for property named 'id' in 'class java.lang.Integer'**错误。

```
User selectByPrimaryKey(@Param(value = "id") Integer id);
```

参考资料：

https://www.cnblogs.com/mmzs/p/8398405.html